

ИНСТРУМЕНТЫ ОЦЕНКИ И РЕГУЛИРОВАНИЯ РИСКОВ РЕАЛИЗАЦИИ КОМПЬЮТЕРНЫХ АТАК

А.А. Остапенко, Е.А. Москалева, М.О. Никитченко, К.В. Щеглов,
Д.И. Шевченко, Я.Е. Попов, М.Д. Неменуций

Целью работы является исследование существующих инструментов оценки и регулирования рисков нарушения кибер безопасности. Поэтому вниманию читателя предлагается анализ концепций, методик и моделей, ориентированных на измерение и приоритизацию информационных рисков, реализацию управления ими. В этом контексте рассматриваются особенности и недостатки соответствующих продуктов компаний Qualys, FAIR- institute, Monaco Risk и других, а также - концепции управления рисками кибер безопасности США. На основе проведенного анализа предлагаются направления и формируются задачи совершенствования методологии риск анализа компьютерных атак.

Ключевые слова: кибербезопасность, оценка рисков, управление уязвимостями, CVSS, CVE, киберриски, информационная безопасность.

Введение

Пожалуй, краеугольной в области обеспечения информационной безопасности остается проблема адекватной оценки и регулирования рисков реализации компьютерных атак. Многочисленные попытки разрешения этой проблемы экспертным путем и сведения результатов, предоставленных экспертами, в разнообразные базы данных (CVSS, CVE, NIST, CWE, CISA KEV, MITRE ATTACK) не устранили сумятицу в процесс моделирования кибервторжений, а попытки частных компаний (Qualys, FAIR-institute, Monaco Risk и других) предложить специалистам по защите информации свое видение проблемы не внесли ожидаемую ясность в методологию риск анализа.

Все вышеизложенное обуславливает необходимость всестороннего исследования существующих инструментов оценки и регулирования киберрисков, чему собственно и посвящена настоящая работа, ориентированная на сравнительный анализ особенностей и недостатков данного инструментария, выявление направлений и формулировку задач его совершенствования.

Базы данных и сведений для осуществления риск-анализа кибератак

CVSS – открытый стандарт для количественной оценки тяжести уязвимостей по шкале от 0 до 10. Преобразует характеристики уязвимости в числовой балл для сравнения потенциального воздействия и сложности эксплуатации [1].

CVE – стандарт идентификации известных уязвимостей через уникальные идентификаторы (например, CVE-2025-XXXX). Служит общей основой для обмена информацией между исследователями, вендорами и системами безопасности [2].

NIST – Национальный институт стандартов и технологий США. Управляет Национальной базой уязвимостей (NVD), которая обогащает записи CVE дополнительными метриками (включая оценки CVSS) и служит центральным репозиторием для анализа и обработки уязвимостей [3].

CWE – каталог стандартизированных типов структурных слабостей (например, переполнение буфера. Описывает абстрактные классы дефектов для анализа причин и профилактики уязвимостей [4].

CISA KEV – каталог Агентства по кибербезопасности США, включающий только подтвержденно эксплуатируемые в реальных атаках уязвимости. Помогает

приоритизировать устранение уязвимостей, представляющих непосредственную угрозу [5].

MITRE ATT&CK – таксономия тактик и техник, используемых злоумышленниками после взлома (например, перемещение по сети, выполнение кода). Служит универсальным языком для анализа поведения угроз, моделирования атак и разработки защитных мер [6].

Концепция управления рисками кибербезопасности США

Долгое время информационная безопасность государственных структур США строилась на так называемой Структуре Управления Рисками (Risk Management

Framework, RMF), объединивший индивидуальные подходы ведомств в одно целостное руководство по обеспечению кибербезопасности. Изначально RMF был разработан и внедрен именно в Министерстве обороны США (DoD). Однако начиная с 2010 года, этот фреймворк был принят в качестве единого стандарта для всех федеральных информационных систем США, а его дальнейшее развитие и поддержка были переданы Национальному институту стандартов и технологий (NIST).

Для понимания контекста этих изменений в табл. 1 приведена динамика параметров концепций США в киберпространстве [7]:

Таблица 1

Динамика концептуальных параметров

Параметр сравнения	Национально-центричный подход (2018 год)	Глобально-ориентированная стратегия (2024 год)
Главный фокус	Защита собственных интересов и технологическое превосходство США	Формирование международных правил, совместимость цифровых систем
Основная цель	Приоритет собственных интересов	Укрепление партнерств, основанных на общих Ценностях и правах человека
Основной подход	Чисто силовой подход в киберпространстве считался достаточным	Осознание ограниченности чисто силового подхода в глобальном и взаимосвязанном киберпространстве
Смещение акцента	Технологическое превосходство	Международное сотрудничество и общие правила

NIST RMF представляет собой комплексный, гибкий и повторяемый процесс, состоящий из нескольких этапов, которые интегрируют безопасность и управление рисками в жизненный цикл системы:

1) prepare (подготовка). Выполнение ключевых действий для подготовки организации к управлению рисками безопасности и конфиденциальности. Установление контекста и основных процессов (стоит уточнить, что этап был добавлен значительно позже, что подчеркивает важность подготовительных организационных действий);

2) categorize (категоризация). Категоризация системы и информации на основе анализа потенциального ущерба в случае нарушения конфиденциальности, целостности или доступности;

3) select (выбор). Выбор надлежащих контрмер (controls) для защиты системы на

основе оценки рисков. Основой служит каталог контрмер NIST SP 800-53;

4) implement (внедрение). Внедрение выбранных контрмер и документирование того, как они развернуты;

5) assess (оценка). Оценка определения того, развернуты ли контрмеры, функционируют ли как предполагалось, и дают ли желаемый результат;

6) authorize (авторизация). Принятие старшим должностным лицом взвешенного решения об авторизации системы к эксплуатации, основанного на понимании остаточного риска;

7) monitor (мониторинг). Непрерывный мониторинг реализации контрмер и рисков для системы.

Необходимость смены этапов оценки продиктована качественным изменением самих угроз, зафиксированных в табл. 2.

Таблица 2

Динамика в оценке роли России в киберстратегиях США

Параметр сравнения	Общая стратегическая конкуренция (2018 год)	Детализированная и контекстуализированная (2024 год)
Характер угрозы	Широкий, системный характер противостояния	Детализированный, привязанный к реальным конфликтам и событиям
Характеристика России	Источник хакерских атак, подрыв демократии, угрозы критической инфраструктуре, участник информационных операций	«Постоянная киберугроза», активно задействует возможности в ходе конфликта в Украине, поддерживает киберпреступников, наращивает потенциал ударов по инфраструктуре США
Фокус стратегии	Фиксирование угроз, описание как части общей группы противников, ведущих киберподрывную деятельность	Точное описание угроз, совместное противодействие в рамках партнерств и цифровой солидарности
Вывод	Акцент на общей стратегической конкуренции и системном характере противостояния	Акцент на конкретных действиях, войне в Украине и международной коалиционной реакции

Помимо поэтапного процесса, RMF основывается на ряде сквозных принципов, которые пронизывают весь цикл управления рисками [8]. Из них можно отметить управление рисками с учетом контекста, привлечение заинтересованных лиц, четкое распределение обязанностей и непрерывное отслеживание и улучшение.

Однако развитие киберпреступности во всем мире показало, что RMF стремительно теряет свою актуальность. В связи с этим, Министерство Войны (бывшее Министерство Обороны) разработало новую модель оценки и регулирования рисков – «Концепцию управления киберрисками» (CSRMC). CSRMC предлагает новаторский подход к обеспечению безопасности систем – круглосуточный мониторинг, панели управления в реальном времени и автоматизированные оповещения. Цель – успевать за современными угрозами и быстрее, чем это позволял предыдущий процесс, предоставлять военным служащим защищенные возможности. И хотя со временем это может повлиять на гражданские системы кибербезопасности, в настоящее время она применима только к Пентагону. В основе этого подхода лежат обновленные принципы цифровой солидарности и технологического превосходства [9], представленные в табл. 3.

Новая концепция организует кибербезопасность в пять этапов (фаз), согласованных с разработкой и эксплуатацией системы:

1) design (проектирование) – Безопасность закладывается с самого начала, обеспечивая встроенную в архитектуру системы устойчивость;

2) build (построение) – Защищенные проекты реализуются по мере достижения системами «начальной операционной готовности»;

3) test (тестирование) – Перед достижением «полной операционной готовности» проводятся всесторонняя валидация и стресс-тестирование;

4) onboard (ввод в эксплуатацию) – При развертывании активируется автоматизированный непрерывный мониторинг для поддержания системы;

5) operations (эксплуатация) – Панели управления в реальном времени и механизмы оповещения обеспечивают немедленное обнаружение угроз и быстрое реагирование.

Помимо этого, CSRMC основана на следующих ключевых принципах:

1) автоматизация (automation) – повышение эффективности и масштабируемости;

2) критические средства контроля (critical controls) – выявление и отслеживание

средств контроля, которые наиболее важны для кибербезопасности;

3) непрерывный мониторинг и постоянное разрешение на эксплуатацию (continuous monitoring, CONMON, control and

АТО) – обеспечение осведомленности о ситуации в реальном времени для поддержания постоянного статуса разрешения на эксплуатацию;

Таблица 3

Принципы концепций киберстратегии США

Принципы	Концепция 2018 год	Концепция 2024 год
1 принцип	«Защита американского народа, Америки и американского образа жизни». Основной задачей является защита американского народа, американского образа жизни и интересов США является основной задачей этой Стратегии. Цель – повышения безопасности и защищенности уже существующих информационных систем и информации.	«Продвигать, создавать и поддерживать открытую, безопасную и устойчивую цифровую экосистему» Стратегия стремится работать с партнерами, частным сектором и гражданским обществом, чтобы катализировать и поддерживать быстрое технологическое развитие. Географический охват международный, сосредоточен на «цифровой солидарности» и работе с союзниками и партнерами. Акцент на инфраструктуре следующего технологического поколения.
2 принцип	«Обеспечение процветания Америки». Основная цель сохранение влияния Соединенных Штатов в рамках технологической опорной инфраструктуры, и разработка киберпространства в качестве открытого двигателя экономического роста, инноваций и эффективности. Обеспечение внутреннего технологического превосходства и создание благоприятной рыночной среды.	«Согласование с международными партнерами подходов к цифровому управлению и управлению данными, основанных на соблюдении прав человека». Этот принцип сфокусирован на создание общих механизмов управления цифровыми технологиями, которые помогут поддерживать открытый, функционально совместимый и надежный интернет, основанный на демократических ценностях, и поддержка надежного потока данных, но сильным акцентом на гарантиях конфиденциальности и прав человека.
3 принцип	«Сохранение мира методом принуждения». Ключевая цель здесь – обеспечение превосходства США в киберпространстве и сдерживание противников через демонстрацию силы и готовность к односторонним действиям. Для этого США заявляли о готовности использовать весь спектр инструментов власти – от киберопераций и санкций до военной силы.	«Содействие ответственному поведению» Смена риторики от «мира через силу» к «стабильности через солидарность и общие правила». Работа в рамках ООН по созданию практических механизмов и, что крайне важно, – прямое подтверждение, что кибератаки могут запускать действие договоров о коллективной обороне, таких как Статья 5 НАТО. Это серьезный стратегический сигнал, формализующий коллективную безопасность в киберпространстве.
4 принцип	Подход, основанный на доминировании и конкуренции моделей глобальной сети. США открыто продвигали свою модель открытого интернета, противопоставляя ее авторитарно модели. Подкреплялось это технологическим превосходством на международном рынке и защитой прав человека. Нарращивание потенциала партнеров рассматривалось, в первую очередь, как инструмент расширения сферы американского влияния.	«Укрепление и наращивание международного партнерства и киберпотенциала». Ключевое слово здесь – «Цифровая солидарность». Если в 2018 году помощь была инструментом влияния, то теперь она стала признаком партнерства и взаимной выгоды. Стратегия 2024 года предлагает партнерам не просто идеалы, а конкретную помощь в разработке политики, кибербезопасности и быстрого реагирования.

4) devSecOps – поддержка безопасной, гибкой разработки и развертывания. DevSecOps – это методология в разработке программного обеспечения, которая интегрирует принципы безопасности на всех этапах жизненного цикла разработки (Dev),

5) операций (Ops) и тестирования, превращая безопасность из отдельного этапа в неотъемлемую часть рабочего процесса;

6) киберживучесть (cyber survivability) – возможность функционирования в так называемой «конфликтной среде» - там, где

противник активно пытается нарушить работу систем;

7) обучение (training) – повышение квалификации персонала для решения усложняющихся задач;

8) корпоративные сервисы и наследование (Enterprise Services & Inheritance) – сокращение дублирования и бюрократической нагрузки;

9) операционализация (operationalization) – обеспечение для заинтересованных сторон

почти реального времени наблюдения состояния киберрисков;

10) взаимность (reciprocity) – повторное использование оценок для разных систем;

11) кибероценки (cybersecurity assessments) – интеграция тестирования на основе данных об угрозах для проверки безопасности.

Более подробно принципы CSRMC отражены в официальной инфографике, которая была мною локализована (рис. 1).



Рис. 1. Локализация инфографики принципов CSRMC

Новая система рассматривает кибербезопасность как непрерывную деятельность, что позволяет отказаться от политики «мгновенных снимков» состояния системы и, вместо этого, переключиться на постоянный мониторинг и реагирование на угрозы, сбора информации об угрозах и внедрения необходимых мер защиты на любом из этапов системы. Это позволит решить ряд ключевых проблем [10].

Во-первых, любой системе подобного стандарта будет выдано «постоянное разрешение на эксплуатацию» (сАТО вместо АТО - Authority to Operate), это позволит отказаться от периодических аудитов и продления этих самых разрешений – предполагается, что система будет устойчива всегда, до её морального устаревания.

Во-вторых, это позволит отказаться от огромного перечня «средств контроля» - по сути мер усиления безопасности системы. Дело в том, что RMF требовал реализации всего базового набора средств контроля NIST SP 800-53, который содержит сотни средств контроля, сгруппированных по 20 семействам (например, «Контроль доступа», «Осведомленность и обучение», «Планирование на случай непредвиденных обстоятельств»). В CSRMC же вместо того чтобы пытаться реализовать все возможные средства контроля из каталога, фокус сместился на Критические средства контроля. Это небольшой набор самых эффективных мер, которые дают максимальный результат для отражения реальных кибератак. Таким образом, сокращается время на

сертификацию и введение системы в эксплуатацию, к тому же сохраняются ресурсы, которые могут быть использованы в иных системах.

Для подготовки системы к новому стандарту, Министерство Войны США предлагает следующее:

1) определить источники данных для системы мониторинга: сканеры уязвимостей, базы данных управления конфигурацией, телеметрия конечных точек и т. д;

2) настроить автоматизированный конвейер, который агрегирует данные, нормализует их и передает на центральную панель управления;

3) определить пороговые значения, которые запускают оповещения; направляйте эти оповещения непосредственно команде дежурных;

4) протестировать систему, чтобы убедиться, что оповещения появляются в реальном времени и что система может поддерживать постоянный статус разрешения на эксплуатацию.

В релизе Минобороны США этот процесс описывается как «повторяемый сценарий», который управляет рисками с помощью автоматизированных панелей управления и оповещений.

Поставщик услуг по кибербезопасности нового поколения (NextGen Cyber Security Service Provider, CSSP), сторонняя компания, предоставляющая услуги по кибербезопасности, действует как центральный орган для ввода в эксплуатацию и мониторинга. Он может:

– полностью ввести систему в эксплуатацию, обеспечив непрерывный мониторинг с первого дня;

– частично ввести систему в эксплуатацию с изоляцией, дополнительным сенсорингом и оценкой рисков.

В обоих случаях поставщик проверяет критически важные средства контроля, собирает обязательные артефакты и передает данные о рисках в систему мониторинга. Он также предоставляет дежурный персонал, который уполномочен отключать систему с высоким риском от сети МО.

Техническая реализация описанных процессов обеспечивается набором

современных инструментов и платформ, утвержденных новой стратегией в табл. 4.

При этом, новая концепция предлагает новую серию инструментов, анализ которых показывает переход от разрозненных и периметро-ориентированных мер защиты к комплексной, централизованной и непрерывной модели кибербезопасности, основанной на принципах автоматизации контроля, унификации платформ и интеграции киберопераций в общую систему командования и управления. Однако, если этот стандарт будет введен – повышение стоимости и сложности обслуживания ввиду автоматизированных систем и индивидуального подхода, а также возможные слепые зоны, которые автоматизированная система может иметь.

Несмотря на технологический прорыв, текущая реализация концепции имеет ряд критических уязвимостей:

1) стратегия «цифровой солидарности» сталкивается с проблемой разного уровня киберзрелости партнеров, что создает «слабые звенья» в общих коалиционных сетях;

2) переход к сАТО (непрерывному разрешению) требует от поставщиков колоссальных ресурсов на поддержание DevSecOps-инфраструктуры, что может отсечь малый инновационный бизнес от госконтрактов;

3) полная передача функций контроля автоматизированным системам может привести к пропуску сложных, медленно развивающихся атак, которые имитируют легитимный трафик.

Для развития концепции CSRMC важны направления, которые решают проблему «человеческого фактора» и обеспечивают интеграцию новых технологий:

1) автоматическая смена сетевых параметров и ключей шифрования в режиме реального времени при обнаружении атак, чтобы противник не успевал закрепиться в системе;

2) создание защищенных шлюзов (API), через которые данные мониторинга CSRMC могут автоматически передаваться союзникам по НАТО без раскрытия секретных алгоритмов самих США;

3) разработка «легкой» версии CSRMC для малых компаний-подрядчиков, чтобы они могли соответствовать требованиям безопасности;

4) создание точных виртуальных копий боевых систем для предварительной обкатки

патчей и проверки на уязвимости перед их внедрением в реальную сеть МО;

5) разработка защиты самих моделей ИИ от «отравления» данных противником, чтобы алгоритмы CSRMC не были обмануты ложными сигналами.

Таблица 4

Инструментарий управления рисками кибербезопасности в США

Инструмент/Система	Функция
Zero Trust Architecture (Архитектура нулевого доверия)	Архитектурная модель; требует постоянной проверки каждого пользователя и устройства для доступа к сети DoD, независимо от их местоположения. Обеспечивает строгий контроль доступа.
Unified Platform (Единая платформа)	Комплексная, секретная программно-аппаратная среда, разработанная для USCYBERCOM. Служит единым набором инструментов для ведения всего спектра киберопераций, например, наступательных, оборонительных, разведывательных.
Joint All-Domain Command and Control (Совместное командование и управление)	Концепция и набор сетевых инструментов, направленных на создание единой, устойчивой и безопасной сети связи между всеми родами войск, для мгновенного обмена данными.
Host-Based Security System (Система безопасности на базе хоста)	Инструмент централизованного управления безопасностью конечных точек, основанный на продукте McAfee ePO. Обеспечивает антивирусную защиту, контроль приложений и предотвращение вторжений на устройствах.
Assured Compliance Assessment Solution (Система гарантированной проверки соответствия)	Программный комплекс на базе Nessus, используемый для автоматизированного сканирования, обнаружения и управления уязвимостями во всей сети DoD. Помогает обеспечить соответствие устройств требованиям безопасности.
Joint Regional Security Stacks (Региональные стеки безопасности)	Консолидированный программно-аппаратный комплекс, который централизует функции сетевой безопасности для нескольких региональных сетей, заменяя разрозненные точки защиты.
Common Access Card (Карта общего доступа)	Физический инструмент строгой двухфакторной аутентификации, типа смарт-карта. Используется для доступа к физическим объектам и входа в информационные системы DoD, являясь частью инфраструктуры открытых ключей.
Cyber Ranges (Киберполигоны)	Специализированные виртуальные и физические среды, оснащенные ПО для имитации реальных боевых кибератак. Используются для обучения персонала USCYBERCOM и тестирования новых систем защиты.
Cyber Maturity Model Certification (Сертификация зрелости модели)	Процесс и инструмент регулирования, который требует от всех подрядчиков Оборонно-промышленной Базы DIB достижения определенного уровня кибербезопасности для работы с секретной информацией DoD.

Таким образом, новая система «Концепция управления рисками кибербезопасности» предлагает совершенно новый, своевременный и перспективный подход, направленный на максимальную «киберживучесть» системы – эффективное реагирование на угрозы и быстрое восстановление, с другой стороны создаст новые вызовы для системы киберобороны США.

Модель факторного анализа информационных рисков от компании FAIR-institute

Исторически сложилось, что управление киберрисками опиралось на качественные

методы: экспертные мнения, матрицы рисков с цветовой индикацией «низкий-средний-высокий». Главный недостаток такого подхода – отсутствие объективной метрики для диалога между ИБ-специалистами и бизнесом. Без перевода рисков в финансовые термины невозможно обосновать бюджет, приоритезировать риски между собой или оценить рентабельность инвестиций в безопасность.

Ответом на эти вызовы стала количественная оценка киберрисков (Cyber Risk Quantification, CRQ). Её цель - выразить риск в понятных бизнесу финансовых показателях (долларах, евро, рублях). Это позволяет рассматривать киберриски наравне

с другими бизнес-рисками. Золотым стандартом в этой области долгое время является методология Факторного Анализа Информационных рисков ФАИР (FAIR) [11].

Методология FAIR (Factor Analysis of Information Risk) [12] была разработана как попытка перевести управление информационными рисками из качественной, экспертно-описательной плоскости в количественную. Ключевая идея FAIR

заключается в представлении риска через формализованные факторы частоты и ущерба, что позволяет выражать результат в денежных единицах и использовать его в управленческих и экономических решениях, таких как обоснование бюджета на безопасность или сравнение эффективности различных контрмер.

Базовая формула FAIR имеет вид:

$$R = LEF \times LM, \quad (1)$$

где R – риск (в трактовке FAIR);

LEF (Loss Event Frequency) – частота убыточных событий;

LM (Loss Magnitude) – величина потерь от одного убыточного события.

Уже на этом уровне следует зафиксировать принципиальный момент: математическая структура формулы соответствует вычислению математического ожидания ущерба за определённый период

(как правило, год), а не риску в строгом теоретико-вероятностном смысле, который подразумевает учёт распределения возможных исходов, их неопределённости и вариативности. Этот аспект будет критически важен для дальнейшего анализа и выявления методологических противоречий.

В FAIR частота убыточных событий подвергается дальнейшей декомпозиции на составляющие факторы:

$$LEF = CF \times PoA \times V, \quad (2)$$

где CF (Contact Frequency) – частота контактов источника угрозы с активом за рассматриваемый период (например, год);

PoA (Probability of Action) – вероятность совершения враждебного действия при наличии контакта (отражает мотивацию и намерение нарушителя);

V (Vulnerability) – вероятность успешной компрометации актива при условии, что атака была предпринята (характеризует степень

уязвимости актива перед конкретной угрозой).

Таким образом, LEF интерпретируется как ожидаемое количество успешных инцидентов за год, являясь результатом перемножения вероятностей на разных этапах возникновения угрозы.

Величина потерь в FAIR представляется как сумма двух основных компонент:

$$LM = Primary Loss + Secondary Loss, \quad (3)$$

где *Primary Loss* – прямые, немедленные потери, непосредственно связанные с инцидентом. Сюда могут входить затраты на восстановление систем и данных, потери от простоя бизнес-процессов, стоимость утраченной или повреждённой информации, а также операционные расходы на реагирование на инцидент,

Secondary Loss – косвенные, отложенные потери, возникающие как последствия инцидента. Типичными примерами являются репутационный ущерб, штрафы от регуляторов, судебные издержки, отток клиентов и партнёров, снижение рыночной стоимости.

Более наглядно логика работы методологии представлена на рис. 2.



Рис. 2. Структура FAIR

Несмотря на формальное наличие этого разбиения, в классической FAIR отсутствует дальнейшая строгая структуризация и формализация этих компонент. На практике они часто оцениваются экспертно и агрегируются в единую денежную величину

без детального анализа внутреннего состава. В связи с большим количеством неточностей, методологию необходимо улучшать. В табл. 5 представлены актуальные проблемы FAIR как методологии оценки рисков и возможные пути решения.

Таблица 5

Оценка проблем FAIR

Проблема FAIR	Описание проблемы	Предлагаемое решение
Подмена понятия риска ожидаемым ущербом	FAIR декларирует количественную оценку риска, однако фактически вычисляет математическое ожидание годового ущерба (Annualized Loss Expectancy). В терминах современной теории риска это не является риском в строгом смысле, поскольку не учитывает распределение исходов (волатильность), неопределённость параметров модели и вариативность возможных сценариев, сводя сложную картину к одному усреднённому значению. Это приводит к методологически некорректной интерпретации результатов.	Пересмотреть назначение модели. Использовать её только для расчета ожидаемого значения ущерба за период времени. Это устранил основное методологическое противоречие и позволит корректно позиционировать модель как инструмент оценки финансовых последствий, пригодный для сравнительного анализа альтернатив и поддержки решений о распределении ресурсов.
Подмена понятия риска ожидаемым ущербом	FAIR декларирует количественную оценку риска, однако фактически вычисляет математическое ожидание годового ущерба (Annualized Loss Expectancy). В терминах современной теории риска это не является риском в строгом смысле, поскольку не учитывает распределение исходов (волатильность), неопределённость параметров модели и вариативность возможных сценариев, сводя сложную картину к одному усреднённому значению. Это приводит к методологически некорректной интерпретации результатов.	Пересмотреть назначение модели. Использовать её только для расчета ожидаемого значения ущерба за период времени. Это устранил основное методологическое противоречие и позволит корректно позиционировать модель как инструмент оценки финансовых последствий, пригодный для сравнительного анализа альтернатив и поддержки решений о распределении ресурсов.
Недостаточная формализация параметра «Уязвимость»	FAIR ориентирована преимущественно на бинарный факт успешной компрометации и практически не учитывает способность системы противостоять развивающейся атаке, деградировать постепенно, а также восстанавливаться после инцидентов. Не учитываются такие параметры, как время до отказа, время восстановления, степень деградации функций.	Введение характеристик динамики функционирования системы, на основе жизненного цикла системы на основе распределения Вейбулла или ему подобных, использование теории надежности для расчета восстановления системы. Таким образом методология перестает быть бинарной,

Проблема FAIR	Описание проблемы	Предлагаемое решение
		что значительно ближе к реальности сложных киберфизических систем.
Отсутствие оценки информационных потерь	В FAIR все потери агрегируются преимущественно в денежном выражении без явного и структурированного выделения ущерба, специфичного для информации как актива – а именно, ущерба от нарушения конфиденциальности, целостности и доступности (CIA).	Введение в компоненты первичного или вторичного ущерба явной оценки информационных потерь системы или её узлов. Такой подход позволяет увязать оценку с общепотребимыми качественными и полуколичественными шкалами, что повышает воспроизводимость, объективность и сопоставимость результатов оценки.

Однако, несмотря на многие неточности и упрощения данной методологии основная проблема заключается в невозможности использования её как основного инструмента расчета и анализа информационных рисков, что прямо противоречит её названию. FAIR является сугубо дополнительной методологией и это обуславливается его главной идеей – оценкой ожидаемого ущерба, а не реального риска.

Графовый риск-анализ эффективности киберконтроля от компании Monaco Risk

Несмотря на все усовершенствования, потенциально реализуемые в FAIR, базовая логика модели остаётся неизменной: результатом расчёта является точечная оценка – ожидаемый годовой ущерб (QALE). Такой подход удобен для финансового планирования, бюджетирования и сравнительного анализа мер защиты в терминах «среднего» случая. Однако он принципиально ограничен при анализе сложных, многоэтапных, адаптивных и взаимосвязанных атак, характерных для современного киберпространства.

Методология GRAACE [13] – графовый риск-анализ эффективности киберконтроля (Graph-based Risk Assessment and Attack Chain Evaluation) была разработана как попытка преодолеть эти ограничения за счёт кардинальной смены парадигмы: перехода от узловых оценок ожидаемого ущерба к анализу графов атак и вероятностных распределений исходов.

В основе GRAACE лежит представление анализируемой системы и угроз в виде ориентированного графа атак (Attack Graph)

или дерева угроз (Attack Tree), где: вершины (узлы) графа соответствуют состояниям или конкретным активам инфраструктуры; рёбра (дуги) графа отражают возможные действия нарушителя, переводящие систему из одного состояния в другое. Каждому ребру сопоставляется вероятность успеха этого действия, а пути в графе от начальной вершины (точки входа) до целевой вершины (цели атаки) представляют собой полноценные сценарии атаки (attack chains).

В отличие от FAIR, где анализ проводится изолированно для каждого актива/события, GRAACE оперирует цепочками событий, что позволяет явно учитывать:

- 1) зависимость этапов атаки друг от друга (для выполнения шага В необходимо сначала выполнить шаг А);
- 2) альтернативные маршруты достижения цели (нарушитель может выбрать другой путь, если основной заблокирован);
- 3) накопление ущерба и повышение привилегий по мере продвижения нарушителя по графу.

Нагляднее работа GRAACE представлена на рисунке упрощенной модели графа кибератак (рис. 6). Как можно заметить, злоумышленник может выбирать любой путь для атаки и оригинальный граф кибератак GRAACE даст сведения о вероятности успешной атаки по каждому атакующему ресурсу MITRE ATT&CK [14]. Пути атак – последовательность конкретных техник MITRE [15]. В конце всех расчетов GRAACE предоставляет самые вероятные пути атаки для конкретной системы.

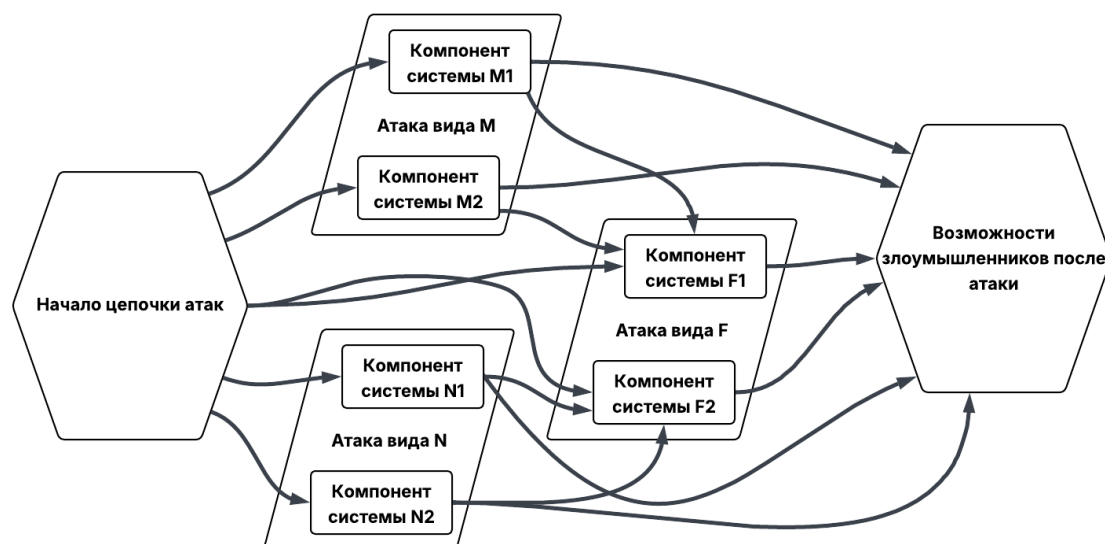


Рис. 3. Упрощенная модель графа кибератак GRAACE

Оценка риска в GRAACE [16] строится на следующих ключевых элементах:

1) построение графа атак для анализируемой системы с учётом её конфигурации, уязвимостей и возможных действий угроз;

2) назначение вероятностей перехода по каждому ребру графа (вероятность успеха конкретного действия);

3) определение функций ущерба, ассоциированных с достижением определённых вершин-состояний (особенно целевых). Ущерб может быть детализирован;

4) анализ графа и агрегация сценариев с использованием методов теории графов и вероятностного моделирования. Моделируется множество случайных прохождений по графу в соответствии с заданными вероятностями.

Вместо вычисления одного значения QALE, GRAACE формирует эмпирическое распределение возможных потерь. На выходе можно получить не только средний ущерб, но и, что критически важно, вероятностные характеристики: вероятность достижения цели, вероятность ущерба, превышающего заданный порог, ожидаемый ущерб в наихудших сценариях.

Ввиду закрытости и новизны модели, нельзя назвать конкретные ошибки в методике GRAACE, однако можно подметить несколько ключевых неточностей:

1) очень высокие требования к входным данным. Необходимо знать топологию

системы, все существенные уязвимости, точно оценивать вероятности успеха сотен действий. Данные часто недоступны или крайне неопределённые;

2) вычислительная и интерпретационная сложность. Построение и анализ графов для крупных систем может быть чрезвычайно ресурсоёмким. Результаты в виде распределений сложнее для восприятия и принятия решений менеджерами, чем одно число QALE;

3) сильная зависимость от экспертных допущений. Назначение вероятностей на рёбрах графа остаётся субъективной процедурой, ошибки в которой могут значительно исказить итоговое распределение.

В целом GRAACE выглядит как перспективная модель, готовая к актуальным киберугрозам, однако компанией-создателем Monaco Risk не было продемонстрировано примеры реального интегрирования их системы в компании или государственные структуры.

Методика оценки и приоритизации киберрисков от компании Qualys

Qualys - глобальный поставщик решений для управления уязвимостями и оценки киберрисков, широко применяемых в корпоративной инфраструктуре [17].

Qualys заявляет о более чем 10 000 клиентских организаций в свыше 130 странах; среди публично известных

пользователей - Aflac, Capital One, Cisco, Amazon.

Отсюда вполне уместно рассмотреть методики, предложенные Qualys по оценке рисков, такие как TruRisk, QVS, QDS [18], а также связанные с ними метрики ACS (Asset Criticality Score) и Asset Exposure.

Прежде всего рассмотрим метрику, именуемую QVS (Qualys Vulnerability Score),

которая по заявлениям Qualys является их собственной оценкой уязвимости (на уровне CVE), показывающей вероятность её эксплуатации. Наглядная схема учета факторов, используемых экспертной командой Qualys при выставлении данной метрики, представлена на рис. 4.

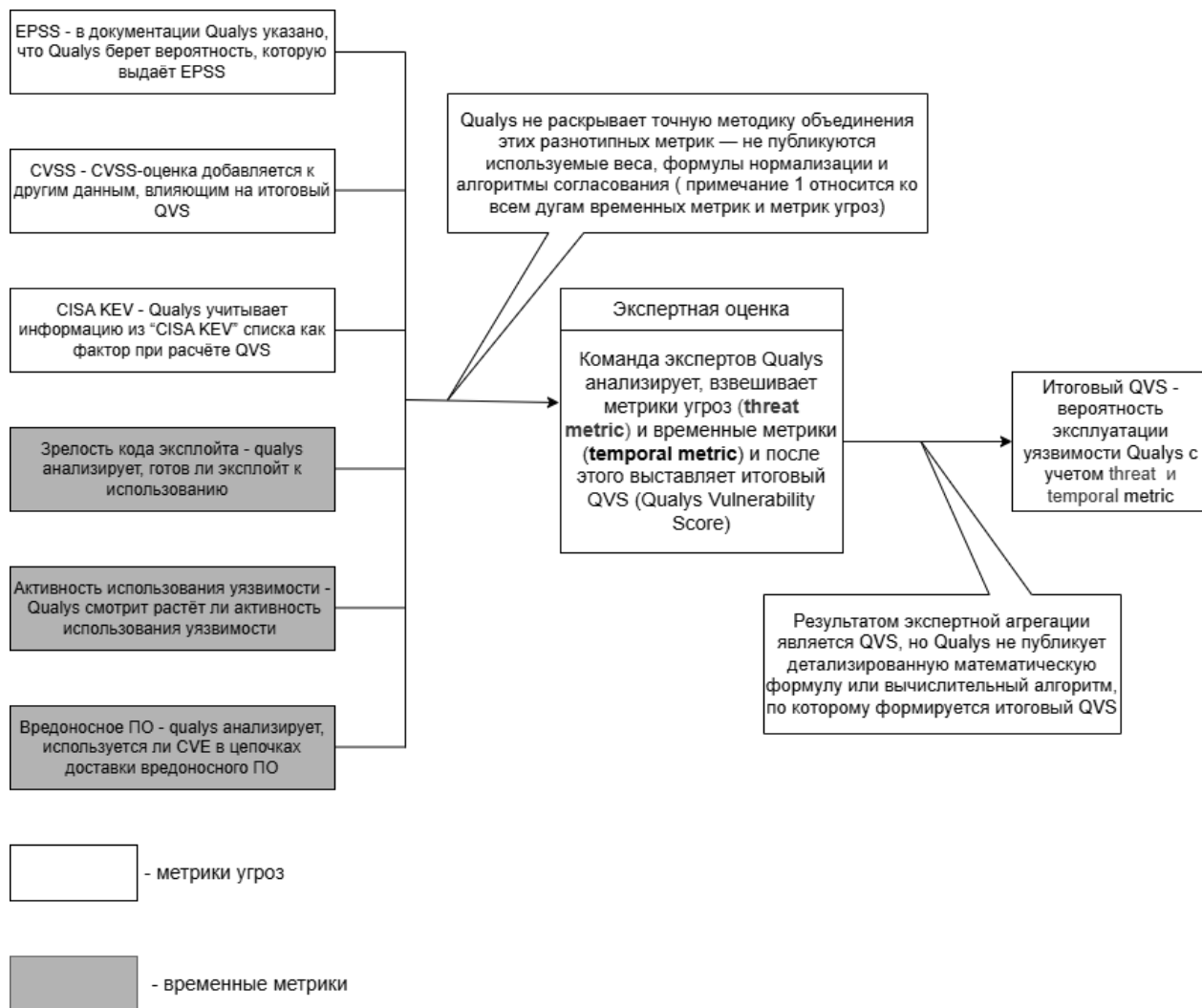


Рис. 4. Схема формирования метрики QVS

Важно отметить, что какие-либо подробности, математической основы того, как рассчитывается метрика, представленная на рис. 1, Qualys не раскрывает публично. Но факт предоставления логики расчета данной метрики может послужить основой для того, какие факторы стоит учитывать при попытках оценить уязвимости с точки зрения вероятности их эксплуатации [19].

Далее рассмотрим схему расчета метрики, прямо связанной с QVS и

именуемой QDS (Qualys Detection Score), представленную на рис. 5.

Все начинается с проверки актива на наличие в нем уязвимостей. Сама же метрика QDS по словам Qualys выражает остаточный риск уязвимости на активе, после учета компенсирующих мер на этом активе, а также учета временных метрик [20].

Также крайне важно отметить, что, как и в случае с QVS, Qualys не публикует какие-либо математические обоснования того, как временные метрики и CID влияют на

конечный QDS [21], формула которого также не публикуется.

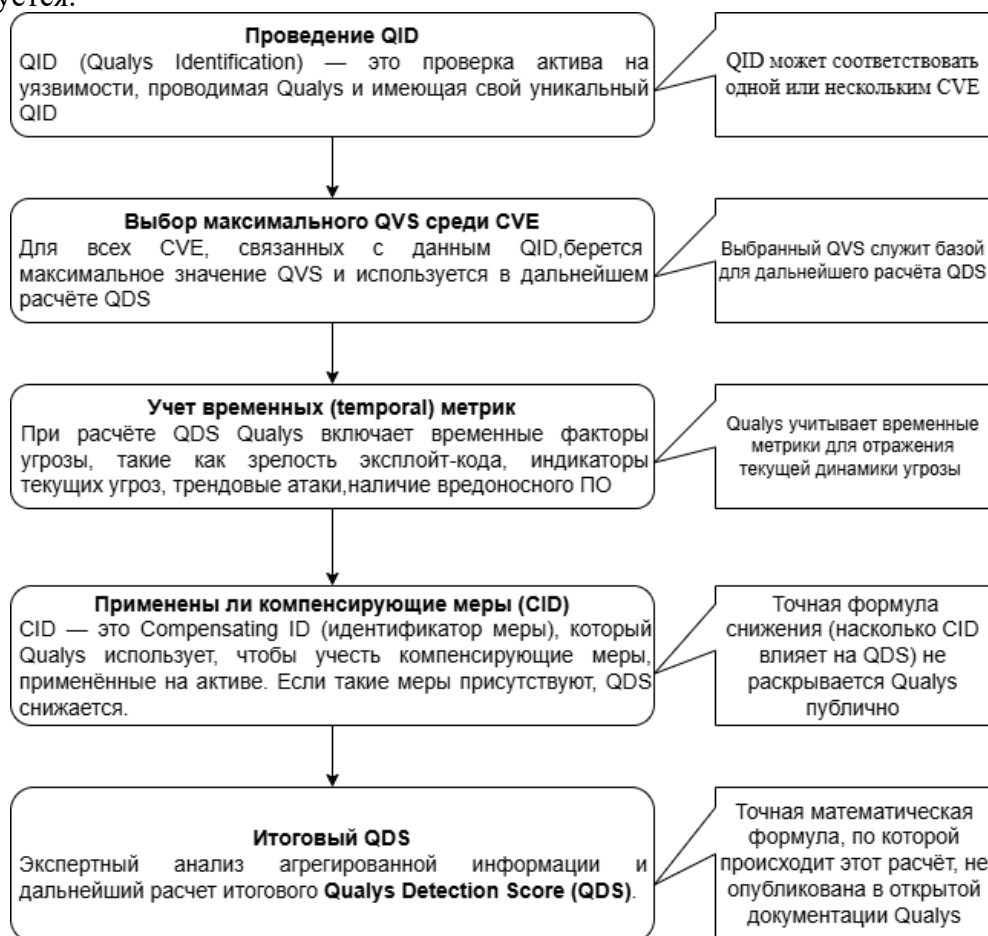


Рис. 5. Схема определения QDS

Однако рассмотрение данной методики может быть полезно при попытках создания собственных методик регулирования рисков уязвимостей на активах (компонентах) различных систем, так как она демонстрирует, какие факторы следует учитывать при этих попытках.

Далее рассмотрим две метрики: ACS (Asset Criticality Score) и Asset Exposure.

ACS (Asset Criticality Score) — это метрика важности актива для бизнес-инфраструктуры компании (диапазон значений 1–5). ACS [22] отражает, насколько важен по мнению экспертов рассматриваемый актив; в формулах TruRisk (рассматриваемых далее) выступает как множитель.

AE (Asset Exposure) - показатель сетевой экспозиции (видимости/доступности) актива из интернета — сколько и каких внешних

признаков делает актив лёгкой целью (публичный IP, открытые сервисы, DNS, сертификаты и др.). В модели TruRisk AE [23] используется как множитель для внешних активов.

Также стоит отметить, что методика выставления данных метрик не раскрывается Qualys публично, но их рассмотрение важно с точки зрения того, что они позволяют понять, какие факторы важны при рассмотрении вопросов регулирования киберрисков в реальной жизни с точки зрения вендоров.

Теперь перейдем к формулам TruRisk для внешних и внутренних активов соответственно. В документации Qualys подчёркивается, что TruRisk [24] — это количественный показатель риска актива.

Формула TruRisk для внутренних активов:

$$\text{TruRisk}_{\text{внутр.}} = \min\left(ACS * \left(\sum_{i \in \{c, h, m, l\}} w_i * \overline{QDS}_i * (\text{Count}(\text{QDS}_i))^{\frac{1}{100}}\right), 1000\right), \quad (4)$$

где ACS (Asset Criticality Score) – отражает важность актива для бизнеса (1–5);

$i \in \{c, h, m, l\}$ – категории критичности уязвимостей: critical, high, medium, low;

w_i – весовые коэффициенты, определяющие относительный вклад каждой категории в общий риск;

$\overline{QDS}_i$ – с редний QDS уязвимостей категории i на активе;

$\text{Count}(\text{QDS}_i)$ – количество уязвимостей данной категории;

$(\text{Count}(\text{QDS}_i))^{\frac{1}{100}}$ – операция, обеспечивающая умеренный рост риска при увеличении количества уязвимостей;

$\text{Min}(..., 1000)$ – ограничение итогового значения в диапазоне 0–1000.

Формула (3) агрегирует все уязвимости актива, взвешивает их по уровню критичности, корректирует по количеству и умножает на бизнес-критичность актива [25].

Формула TruRisk для внешних активов принимает следующий вид:

$$\text{TruRisk}_{\text{внеш.}} = \min(\text{AE} * \text{ACS} * (\sum_{i \in \{c, h, m, l\}} w_i * \overline{QVS}_i * (\text{Count}(\text{QVS}_i))^{\frac{1}{100}}), 1000), \quad (5)$$

где AE (Asset Exposure) – показатель сетевой экспозиции (1÷5), отражающий доступность ресурса из интернета: публичный IP, открытые порты, DNS, TLS-сертификаты, OSINT-видимость.

В формуле (4) для внешних активов добавляется параметр AE, учитывающий, показатель сетевой экспозиции, отражающий доступность ресурса из интернета.

Добавление параметра Asset Exposure в формулу TruRisk для внешних активов отражает принципиальное различие в характере угроз для ресурсов, находящихся под прямой или косвенной доступностью из сети Интернет. В отличие от внутренних активов, для которых вероятность атаки в значительной степени определяется внутренним контуром безопасности организации, внешние активы подвержены воздействию более широкого круга потенциальных нарушителей. Наличие публичного IP-адреса, открытых сетевых сервисов, доменных записей, TLS-сертификатов и иных признаков внешней видимости существенно увеличивает вероятность попыток эксплуатации уязвимостей, даже при сопоставимом уровне их технической критичности.

Анализ вышеприведенного методического обеспечения позволяет сделать ряд выводов, которые сведены в табл. 6.

Таким образом, в исследовании просматриваются следующие проблемные

точки: экспертная природа весовых коэффициентов, непрозрачность внутренних алгоритмов QVS/QDS, дискретная шкала ACS/AE, необоснованный выбор функции учёта количества обнаружений, а также смешение угрозных и бизнес-компонентов в единой формуле. Каждое из этих ограничений имеет прямое влияние на интерпретацию результатов: отсутствие прозрачных весов и формул препятствует воспроизводимости и аудитуемости расчётов; дискретизация ACS/AE и произвольная форма учёта Count вносят дополнительные искажения при ранжировании активов.

Тем не менее, изучение предложенной Qualys структуры полезно и практически ценно. Во-первых, она ясно показывает набор факторов, которые индустрия считает важными: данные из CVSS, вероятность эксплуатации уязвимости из EPSS, наличие в списках известных эксплуатаций (CISA KEV), зрелость кода-эксплойта, и контекст актива (ACS, AE). Во-вторых, сама идея комбинирования разведанных и бизнес-контекста даёт рабочую архитектуру для построения внутренних моделей приоритизации - даже если конечная формула должна быть иной. К тому же, риск-методика Qualys служит практическим ориентиром в том, какие данные необходимо собирать, а также какие зависимости важно установить и риск анализа кибербезопасности.

Таблица 6

Недостатки методики Qualys и пути ее совершенствования

Рассматриваемый аспект	Недостатки инструментария	Пути совершенствования инструментария
Экспертная природа весовых коэффициентов w_i	Весовые коэффициенты, используемые Qualys для категорий уязвимостей (critical/high/medium/low), не обоснованы математически. Они определены исключительно экспертным методом внутри компании, что затрудняет независимую верификацию модели. В итоге, значение TruRisk частично основывается не на данных, а на экспертных допущениях вендора.	Учет факта экспертного задания весов подсказывает необходимость перехода к прозрачному и воспроизводимому способу задания весов в собственной методике. Уместно - формализовать процедуру калибровки весов (например, на исторических инцидентах или через экспертные анкетирования), что повысит доверие к создаваемой модели и позволит адаптировать ее под специфику объекта исследования.
Непрозрачная внутренняя конструкция QDS и QVS	Qualys публикует только описание методики расчета QVS и QDS, но не раскрывает математическую формулу: неизвестны веса факторов, способ нормализации, порядок объединения CVSS, EPSS, KEV и др. Это делает модель по сути «чёрным ящиком», полностью зависящим от внутренней логики платформы.	Обновленная методика должна быть документируемой и верифицируемой, то есть явно фиксировать источники входных данных, формулы нормализации, порядок агрегирования, что даёт возможность воспроизводимости расчётов, независимой проверки результатов и сравнения альтернативных вариантов.
Использование экспертных оценок вместо расчетных (ACS, AE)	ACS и AE выражены в виде дискретных категорий 1÷5. Переход между этими категориями вызывает скачкообразные изменения риска, а смешивание таких дискретных значений с непрерывными метриками QDS приводит к математической неоднородности модели.	В отличие от подхода, реализуемого Qualys, при разработке собственного инструментария, требуется учитывать все недостатки рассмотренной модели и использовать расчетные оценки, которые позволят более точно отражать приводимую оценку метрик, применяемых в собственных методиках.
Необоснованность метода учета количества уязвимостей $\left(Count(QDS_i)\right)^{\frac{1}{100}}$	Использование корня степени 1/100 не имеет формального обоснования ни в теории риска, ни в математической статистике. Этот множитель создан якобы для уменьшения влияния большого количества уязвимостей. Однако выбранная степень может приводить к непредсказуемым нелинейным эффектам.	Понимание того, что этот множитель - крайне не точен и не обоснованно введен, делает полезным в собственной методике формализовать обоснование выбираемого метода (функции) для учёта количества уязвимостей: сравнить альтернативы (линейная, логарифмическая, степенная) и выбирать на основе данных и получаемых результатов. Обязателен анализ чувствительности и отчёт о том, почему выбран именно такой способ, чтобы не вводить скрытые эффекты при масштабировании.
Смещение разнородных параметров	В одной формуле TruRisk перемножаются показатели угроз (QDS/QVS), бизнес-критичность (ACS), количество уязвимостей и сетевая экспозиция актива (AE). Их совместное использование не корректно уже исходя из размерности параметров.	Важно при разработке альтернативной методики чётко разделять разнородные сущности и если их использовать, то делать это обоснованно в различных аналитических выражениях, корректно задавая их единицы измерения и методику приведения к общей шкале. Это поможет избежать математической неразберихи и даст возможность адекватно интерпретировать результат.

Наконец, рассмотрение отраслевых подходов помогает сформировать понимание компромиссов между их точностью, масштабируемостью и прозрачностью. Изучение и критика индустриальных алгоритмов дают практический материал для построения собственных моделей, что в конечном счёте повышает качество реализуемых решений. В свете изложенного, инструментальные наработки Qualys следует рассматривать как полезную операционную структуру действий, требующую собственной методической «начинки» и адаптации под специфику защищаемой системы.

Заключение

В настоящей работе продемонстрирована практическая и методологическая значимость анализа современных подходов к управлению киберрисками: от нормативно-ориентированных конструкторов RMF/NIST и операционно-ориентированной CSRMC до прикладных количественных методик FAIR, продуктовых метрик вендоров (Qualys) и графовых моделей анализа атак (GRAACE). Каждый из рассмотренных инструментов вносит свой вклад в общее понимание проблемы: RMF и CSRMC задают жизненный цикл и институциональные принципы управления рисками, делая акцент на интеграции безопасности в жизненный цикл систем и на непрерывном мониторинге; FAIR предлагает перевод рисков в бизнес-понятия через денежную оценку ожидаемых потерь, что облегчает бюджетирование и принятие экономически обоснованных решений; методики вендоров и платформы управления уязвимостями демонстрируют набор практических признаков и метрик, необходимых для приоритизации работ по устранению уязвимостей; графовые подходы, в свою очередь, расширяют аналитический инструментарий, позволяя моделировать цепочки атак и получать вероятностные распределения потерь, более адекватные для сложных взаимосвязанных систем. На этом фоне очевидна комплементарность методов: количественная оценка ожидаемого ущерба пригодна для финансового планирования, тогда как графовый анализ и данные разведки

угроз необходимы для сценарного анализа и оперативной приоритизации контрмер.

Вместе с тем, анализ выявил существенные ограничения и предупреждает о рисках некритичного переноса методов «как есть» в практику организаций. FAIR, будучи удобным инструментом для получения одного скалярного показателя (ожидаемого годового ущерба), не отражает волатильности и распределения исходов, что снижает его применимость в ситуациях с высокой неопределённостью и редкими катастрофическими событиями; продуктовые метрики нередко остаются «чёрными ящиками» без прозрачной математической основы, что затрудняет верификацию и воспроизводимость результатов; графовые модели требуют значительных объёмов данных и вычислительных ресурсов, а также аккуратного обращения с экспертными допущениями при назначении вероятностей переходов. Эти методологические ограничения указывают на необходимость тщательной адаптации методов под конкретный контекст организации: обеспечение прозрачности и воспроизводимости вычислений, учет динамики функционирования и восстановления систем, формализация весов и допущений, а также комбинирование моделей для получения как агрегированных бизнес-метрик, так и распределений сценарных исходов.

Практическая польза от всестороннего рассмотрения описанных методик заключается в возможности выстроить многоуровневую систему управления рисками, сочетающую стратегическое управление и нормативную базу с оперативными инструментами приоритизации и сценарного моделирования. Интеграция принципов CSRMC и RMF обеспечивает организационную готовность и непрерывность процессов, количественные подходы типа FAIR дают совместимый с бизнесом язык для обоснования инвестиций, вендорские метрики и платформы указывают на набор данных и телеметрии, необходимых для автоматизированного мониторинга, а графовые подходы позволяют глубже понять пути и последствия атак. Именно сочетание этих элементов – при условии корректной

калибровки, прозрачности и учета человеческого фактора - создаёт основу для устойчивой и адаптивной системы управления киберрисками, способной как обосновывать ресурсные решения на уровне руководства, так и поддерживать оперативную готовность к реальным угрозам.

Вместе с тем, наиболее полную картину для анализа дают аналитические методы, опирающиеся на теорию вероятностей и сценарные модели кибератак во всем многообразии их разновидностей эксплуатируемых уязвимостей. Именно в этом направлении видится перспектива развития теории и практики управления информационными рисками.

Список литературы

1. CVSS (Common Vulnerability Scoring System) URL: <https://www.first.org/cvss/> (дата обращения: 12.11.2025).
2. CVE (Common Vulnerabilities and Exposures) URL: <https://cve.mitre.org/> (дата обращения: 12.11.2025).
3. NIST (National Institute of Standards and Technology) URL: <https://nvd.nist.gov/> (дата обращения: 12.11.2025).
4. CWE (Common Weakness Enumeration) URL: <https://cwe.mitre.org/> (дата обращения: 12.11.2025).
5. CISA KEV (Known Exploited Vulnerabilities Catalog) URL: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog> (дата обращения: 12.11.2025).
6. MITRE ATT&CK URL: <https://attack.mitre.org/> (дата обращения: 12.11.2025).
7. National Cyber Strategy USA 2018 URL: <https://trumpwhitehouse.archives.gov/wp-content/uploads/2018/09/National-Cyber-Strategy> (дата обращения: 12.11.2025).
8. Risk Management URL: <https://www.nist.gov/risk-management> (дата обращения: 6.12.2025).
9. International Cyberspace and Digital Policy Strategy 2024 URL: <https://www.state.gov/united-states-international-cyberspace-and-digital-policy-strategy/> (дата обращения: 12.11.2025).
10. Department of War Announces New Cybersecurity Risk Management Construct URL: <https://www.war.gov/News/Releases/Release/Article/4314411/departments-of-war-announces-new-cybersecurity-risk-management-construct/> (дата обращения: 12.11.2025).
11. Quantitative Information Risk Management | The FAIR Institute URL: <https://www.fairinstitute.org/> (дата обращения: 12.11.2025).
12. The Importance and Effectiveness of Cyber Risk Quantification | The FAIR Institute URL: <https://www.fairinstitute.org/what-is-fair> (дата обращения: 12.11.2025).
13. Cyber Risk Quantification Models: FAIR™ vs GRAACE™ URL: <https://www.monacorisk.com/post/cyber-risk-quantification-models-fair-vs-graace> (дата обращения: 12.11.2025).
14. MITRE ATT&CK® URL: <https://attack.mitre.org/> (дата обращения: 12.11.2025).
15. Techniques - Enterprise | MITRE ATT&CK® URL: <https://attack.mitre.org/techniques/enterprise/> (дата обращения: 12.11.2025).
16. Why Monaco Risk? | Monaco Risk URL: <https://www.monacorisk.com/why-monacorisk> (дата обращения: 12.11.2025).
17. Qualys URL: <https://www.qualys.com/company> (дата обращения: 12.11.2025).
18. Qualys Detection Score URL: <https://clck.ru/3QrB5D> (дата обращения: 3.12.2025).
19. Qualys Security Blog URL: <https://blog.qualys.com> (дата обращения: 12.11.2025).
20. Understanding the Qualys Detection Score URL: <https://clck.ru/3QrB3n> (дата обращения: 12.11.2025).
21. Effective Vulnerability Management URL: <https://clck.ru/3QrBZ7> (дата обращения: 12.11.2025).
22. Asset Details URL: <https://clck.ru/3QrBCg> (дата обращения: 12.11.2025).
23. Qualys TruRisk URL: <https://clck.ru/3QrBLi> (дата обращения: 12.11.2025).
24. Display TruRisk Details (ARS, ACS, QDS) URL: <https://clck.ru/3QrBoD> (дата обращения: 12.11.2025).

25. Calculating TruRisk Score URL: <https://clck.ru/3QrBTZ> (дата обращения: 12.11.2025).
26. Qualys Documentation - TruRisk Score Model URL: <https://clck.ru/3QrBdd> (дата обращения: 12.11.2025).
27. How the Qualys Enterprise TruRisk - TruRisk Score Model URL: <https://clck.ru/3QrBkU> (дата обращения: 12.11.2025).

Воронежский государственный технический университет
Voronezh State Technical University

Поступила в редакцию 20.11.2025

Информация об авторах

Остапенко Александр Алексеевич – аспирант, Воронежский государственный технический университет, e-mail: alexanderostapenkoias@gmail.com

Москалева Екатерина Алексеевна – канд. техн. наук, доцент, Воронежский государственный технический университет, e-mail: alexanderostapenkoias@gmail.com

Никитченко Михаил Олегович – студент, Воронежский государственный технический университет, e-mail: maikl.nikitchenko@yandex.ru

Щеглов Кирилл Витальевич – студент, Воронежский государственный технический университет, e-mail: kiryusha.shheglov@mail.ru

Шевченко Дарья Ивановна – студент, Воронежский государственный технический университет, e-mail: shevchenkodashka@yandex.ru

Попов Ярослав Евгеньевич – студент, Воронежский государственный технический университет, e-mail: yarik.popov.2004@gmail.ru

Неменуший Максим Дмитриевич – студент, Воронежский государственный технический университет, e-mail: alexanderostapenkoias@gmail.com

TOOLS FOR ASSESSMENT AND REGULATION OF COMPUTER ATTACK IMPLEMENTATION RISKS

**A.A. Ostapenko, E.A. Moskaleva, M.O. Nikitchenko, K.V. Shcheglov,
D.I. Shevchenko, Ya.E. Popov, M.D. Nemenushchiy**

The aim of this work is to investigate existing tools for assessing and regulating cyber security breach risks. Therefore, the reader is presented with an analysis of concepts, methodologies, and models focused on measuring and prioritizing information risks, as well as implementing their management. In this context, the features and shortcomings of the relevant products from companies such as Qualys, FAIR Institute, Monaco Risk, and others are examined, along with the concepts of cyber security risk management in the United States. Based on the conducted analysis, directions for improvement are proposed and tasks are formulated for enhancing the methodology of computer attack risk analysis.

Keywords: cybersecurity, risk assessment, vulnerability management, CVSS, CVE, cyber risks, information security.

Submitted 20.11.2025

Information about the authors

Alexander A. Ostapenko – Postgraduate Student, Voronezh State Technical University, e-mail: alexanderostapenkoias@gmail.com

Ekaterina A. Moskaleva – Cand. Sc. (Technical), Associate Professor, Voronezh State Technical University, e-mail: alexanderostapenkoias@gmail.com

Mikhail O. Nikitchenko – Student, Voronezh State Technical University, e-mail: maikl.nikitchenko@yandex.ru

Kirill V. Shcheglov – Student, Voronezh State Technical University, e-mail: kiryusha.shheglov@mail.ru

Daria I. Shevchenko – Student, Voronezh State Technical University, e-mail: shevchenkodashka@yandex.ru

Yaroslav E. Popov – Student, Voronezh State Technical University, e-mail: yarik.popov.2004@gmail.ru

Maxim D. Nemenushchiy – Student, Voronezh State Technical University, e-mail: alexanderostapenkoias@gmail.com